

VULNERABILITY ASSESSMENT REPORT

Web Application & Database Penetration Testing — Critical Chain Finding

Full System Compromise via Leaked Database Credentials and xp_cmdshell Escalation

Vulnerability Class: Sensitive Data Exposure / Improper Configuration / RCE

CWE References: CWE-312, CWE-89, CWE-78

Attack Type: Multi-Stage Chain — Disclosure → Credential Abuse → RCE

Target: [REDACTED] — withheld per responsible disclosure policy

SEVERITY RATING

CRITICAL

Full System Compromise

Report Reference: VAR-2025-RCE-021

Date of Assessment: [REDACTED]

Target: [REDACTED] — identifying details withheld

Classification: **CONFIDENTIAL — For Authorised Personnel Only**

1. Executive Summary

A critical multi-stage vulnerability chain was identified during a security assessment of the target application. The chain originates from an insecurely stored archive file accessible from a public-facing directory and culminates in full Remote Code Execution (RCE) on the underlying host operating system. No authentication bypass, social engineering, or zero-day exploit was required at any stage of the attack path.

The attack chain consists of three sequential phases: an information disclosure phase in which plain-text database credentials are extracted from a publicly accessible configuration archive; a credential abuse phase in which these credentials are used to establish an authenticated administrative connection to the SQL Server; and an escalation phase in which the xp_cmdshell extended stored procedure is enabled via the compromised administrative account, granting unrestricted command execution on the host operating system.

 Critical Risk Assessment

This finding represents a complete compromise of the affected system's security boundary. An unauthenticated external attacker following the documented attack path would achieve SYSTEM or SA-level code execution on the host within minutes of identifying the initial archive file. All data stored on the server and all systems reachable from it must be considered compromised until full remediation is confirmed.

Vulnerability Summary

Vulnerability Name	Full System Compromise via Leaked DB Credentials and xp_cmdshell
Severity	Critical — Full Remote Code Execution achieved
Vulnerability Class	Sensitive Data Exposure / Improper Configuration / RCE
CWE References	CWE-312 (Cleartext Storage), CWE-89 (SQL Injection), CWE-78 (OS Command Injection)
OWASP Category	A02:2021 Cryptographic Failures — A05:2021 Security Misconfiguration
Attack Type	Multi-Stage Chain: Disclosure → Credential Abuse → Privilege Escalation → RCE
Authentication Req.	None — Initial access requires no credentials or prior knowledge
Target	[REDACTED] — withheld per responsible disclosure policy
Report Reference	VAR-2025-RCE-021
Status	Critical — Immediate Remediation Required

2. Technical Attack Path

The following section documents the complete attack chain in the order it was executed during the assessment. Each phase is dependent on the preceding phase and represents a distinct vulnerability in its own right. The chain as a whole constitutes a Critical finding; each individual phase would independently warrant remediation.

Phase 1: Information Disclosure — Publicly Accessible Archive Containing Plain-Text Credentials

During web application reconnaissance, a publicly accessible .rar archive file was discovered within a directory served by the target web server. Archive files of this type are commonly uploaded or left in place during deployment and maintenance operations and are frequently overlooked during security reviews.

Upon extraction of the archive, an XML application configuration file (consistent with a web.config or app.config deployment artefact) was found to contain the following sensitive values in plain text:

Configuration Key	Value Exposed
Data Source	[REDACTED] — Public-facing IP address of the SQL Server host
User ID	[REDACTED] — Administrative database account (e.g. sa or equivalent)
Password	[REDACTED] — Plain-text administrative password
Port	1433 (Microsoft SQL Server default) — directly internet-accessible

i Redaction Note

All sensitive values extracted from the configuration file — including IP addresses, usernames, and passwords — have been redacted from this published report. The unredacted evidence is retained securely and available to the affected organisation upon verified request.

Phase 2: Database Access — Authenticated Administrative Connection via Leaked Credentials

Using the credentials obtained in Phase 1, an authenticated connection was established to the remote SQL Server instance. The database port (TCP 1433) was confirmed to be directly reachable from an external network without traversing a firewall or VPN boundary. Connection was established using the sqlcmd command-line client.

```
# Phase 2 - Database Connection (sqlcmd)
# Authenticate to the remote SQL Server using recovered credentials
sqlcmd -S [REDACTED_IP] -U [REDACTED_USERNAME] -P [REDACTED_PASSWORD]

# Result: Successful authentication - administrative session established
# Server version and instance name confirmed in initial banner
```

Successful authentication confirmed that the credentials recovered from the archive file were valid and active. The account obtained had sysadmin-level privileges on the SQL Server instance, granting full control over all databases, server configuration settings, and extended stored procedures.

Phase 3: Escalation to RCE — xp_cmdshell Enablement and OS Command Execution

With sysadmin access to the SQL Server instance confirmed, the xp_cmdshell extended stored procedure was enabled. By default, SQL Server ships with this feature disabled as a security measure; however, any account with sysadmin-level privileges can re-enable it through the sp_configure system procedure without requiring any additional credentials or elevated OS-level permissions.

The following T-SQL sequence was executed within the authenticated session to enable xp_cmdshell and subsequently execute operating system commands:

```
# Phase 3 - xp_cmdshell Enablement and RCE (T-SQL)
-- Step 1: Enable advanced configuration options
EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;

-- Step 2: Enable the xp_cmdshell extended stored procedure
EXEC sp_configure 'xp_cmdshell', 1;
RECONFIGURE;

-- Step 3: Execute an OS-level command via the SQL Server service account
EXEC xp_cmdshell 'whoami';

-- Result: OS command output returned directly in SQL query results
-- Confirms RCE with the privileges of the SQL Server service account
```

Execution of the whoami command returned the identity of the SQL Server service account, confirming that arbitrary operating system commands can be executed on the host. From this position, an attacker has unrestricted access to the host file system, network interfaces, and all processes running under the service account's privilege level.

3. Impact Analysis

The successful execution of this attack chain results in a complete compromise of the affected system. The following impact dimensions represent post-exploitation capabilities available to an attacker who has reached Phase 3 of the chain described above.

3.1 Full System Takeover

Via `xp_cmdshell`, an attacker can execute arbitrary commands on the Windows or Linux host with the privileges of the SQL Server service account. In many default or misconfigured deployments, this account operates with elevated OS-level permissions (e.g. `LocalSystem` or a domain service account). At minimum, the attacker controls all resources accessible to the service account, including the SQL Server data directory, log files, and network sockets.

3.2 Complete Data Exfiltration

With `sysadmin`-level database access, an attacker has read and write access to all databases hosted on the instance. This encompasses all user records, authentication credentials, financial transactions, personally identifiable information (PII), and any other structured data stored within the database tier. Exfiltration can be performed silently via outbound HTTP or DNS channels initiated through `xp_cmdshell` without triggering standard database audit logs.

3.3 Lateral Movement and Pivoting

The compromised database server, being network-connected and under full attacker control, can be used as a pivot point to enumerate and attack other hosts on the internal network. The SQL Server service account credentials, local administrative hashes, and network routing information obtainable from the compromised host may allow the attacker to expand access to adjacent systems without re-entering through the perimeter.

3.4 Ransomware and Destructive Payload Deployment

With command execution capability on the host, an attacker can download and execute arbitrary binaries, including ransomware, persistent backdoors, or data-wiping payloads. The SQL Server file system access also permits direct encryption or deletion of database files, rendering the service unavailable and potentially destroying data that has not been backed up externally.

Impact Dimension	Severity	Description
Confidentiality	CRITICAL	All database content and host file system readable
Integrity	CRITICAL	Arbitrary data modification and file system write access
Availability	CRITICAL	Service disruption, data destruction, ransomware risk
Scope	CHANGED	Lateral movement risk extends impact beyond initial host

4. Remediation Recommendations

The following remediation actions address each phase of the attack chain individually and together. All items rated Critical Priority should be treated as immediate actions to be completed within 24 hours of this report being received. Failure to act on the Critical Priority items leaves the system in a state of active, exploitable compromise.

4.1 Remove the Publicly Accessible Archive File [Priority: Critical — Immediate]

The archive file containing the configuration data must be removed from the publicly accessible web directory immediately. All web-accessible directories should be audited for the presence of archive files (.rar, .zip, .tar.gz, .bak), configuration files (.config, .xml, .env, .ini), and any other files that are not explicitly required to serve application content.

- Delete the archive file from the web root and any staging or backup directories accessible via HTTP.
- Conduct a full audit of the web-accessible directory tree for any additional sensitive files that may have been inadvertently exposed.
- Configure the web server to deny requests for archive and configuration file extensions at the server level (e.g. via MIME type restrictions or explicit deny rules).

4.2 Rotate All Exposed Credentials Immediately [Priority: Critical — Immediate]

The database credentials disclosed in the configuration file must be treated as fully compromised and rotated without delay. Rotation alone is insufficient if the credentials are re-stored in an insecure manner; the storage mechanism must also be corrected as part of this action.

- Immediately change the password of the exposed administrative database account.
- Audit all application connection strings and configuration files for the presence of plain-text credentials.
- Migrate credentials to a secrets management solution such as Azure Key Vault, AWS Secrets Manager, or HashiCorp Vault, with access controlled by managed identity or IAM role rather than static credentials.
- Never store credentials in XML or plain-text configuration files committed to source control or deployed to web-accessible directories.

4.3 Disable xp_cmdshell and Enforce Least Privilege [Priority: Critical — Immediate]

The xp_cmdshell extended stored procedure should be confirmed as disabled on the SQL Server instance. Additionally, the SQL Server service account should be reviewed and restricted to the minimum permissions required for application functionality.

```
# Disable xp_cmdshell - T-SQL
-- Disable xp_cmdshell and remove advanced options visibility
EXEC sp_configure 'xp_cmdshell', 0;
RECONFIGURE;

EXEC sp_configure 'show advanced options', 0;
RECONFIGURE;

-- Verify the configuration has been applied
EXEC sp_configure 'xp_cmdshell';
-- Expected: run_value = 0
```

- Ensure the SQL Server service account runs under a dedicated low-privilege local or domain account, not LocalSystem or Administrator.

- Apply the Principle of Least Privilege: the application database user should have only SELECT, INSERT, UPDATE, and DELETE permissions on the specific databases it requires, not sysadmin.

4.4 Restrict Network Access to the Database Port [Priority: Critical — Immediate]

SQL Server (TCP port 1433) must not be directly accessible from the public internet under any circumstances. Database services should only accept connections from application servers within the same private network or subnet, enforced at the network layer.

- Apply firewall rules to block all inbound connections to TCP 1433 from external (non-RFC1918) source addresses.
- If remote administrative access to the database is operationally required, restrict it to specific administrator IP addresses via IP whitelisting, or require access through a VPN or bastion host.
- Conduct a full port scan of the server's public IP address to identify any additional services exposed to the internet that should be restricted.

4.5 Implement a Deployment Security Checklist [Priority: High]

The presence of a credential-bearing configuration archive in a public web directory indicates a gap in the deployment or release management process. The following preventive controls should be implemented to ensure this class of vulnerability cannot recur:

- Integrate a pre-deployment static analysis step that scans for credentials, secrets, and sensitive file extensions prior to any production release.
- Implement .gitignore and deployment exclusion rules that explicitly prevent configuration files and archive files from being included in web deployable artefacts.
- Adopt a secrets scanning tool (e.g. truffleHog, git-secrets, or equivalent) as part of the CI/CD pipeline to detect credential exposure before code reaches production.

5. References

- CWE-312: Cleartext Storage of Sensitive Information — <https://cwe.mitre.org/data/definitions/312.html>
- CWE-78: OS Command Injection — <https://cwe.mitre.org/data/definitions/78.html>
- Microsoft Documentation — xp_cmdshell (Transact-SQL): <https://learn.microsoft.com/en-us/sql/relational-databases/system-stored-procedures/xp-cmdshell-transact-sql>
- OWASP Top 10 2021 — A02: Cryptographic Failures
- OWASP Top 10 2021 — A05: Security Misconfiguration
- Microsoft SQL Server Surface Area Configuration Best Practices
- NIST SP 800-123 — Guide to General Server Security

End of Report

VAR-2025-RCE-021 — Full System Compromise via Leaked Credentials & xp_cmdshell
CONFIDENTIAL — All target-identifying information has been redacted for responsible disclosure